

POCKETTERM35 · NARZĘDZIE DLA ADMINÓW

autoscan — przewodnik po skanach

Co robi każdy skan i jakich narzędzi używa. Od błyskawicznego recon, przez pełny audyt i red team, po utwardzanie serwera (blue team).

⚡ Szybki

🔍 Zwyczajny

💪 Głęboki

💣 Red Team

🛡️ Blue Team

Raporty zapisują się w `~/audyt-raporty/` jako **HTML**.
Repo: github.com/altgreen64/pocketterm35

⚠️ **Tylko własne sieci albo audyt z pisemną zgodą.** Nieautoryzowany skan cudzej sieci jest nielegalny. Narzędzie służy do nauki bezpieczeństwa i obrony własnej infrastruktury.

Jak działa skan — 5 faz

Każdy skan (poza blue team) przechodzi przez te same fazy. Profile różnią się tylko głębokością i tym, co dokładają.

- 1 Rozpoznanie ARP** — `netdiscover`
Kto żyje w segmencie sieci (adresy MAC/IP sąsiadów na warstwie łącza).
- 2 Wykrycie żywych hostów** — `nmap -sn`
Ping sweep po całej podsieci — potwierdza, które adresy odpowiadają.
- 3 Usługi, wersje, system, podatności** — `nmap -sV -O --script vuln`
Otwarte porty, nazwy i wersje usług, zgadywanie systemu operacyjnego oraz skrypty NSE wykrywające znane podatności (lekki odpowiednik skanera podatności).
- 4 Serwery WWW i TLS** — `nikto · dirb · testssl`
Dla wykrytych usług webowych: znane luki serwera (nikto), ukryte katalogi (dirb), audyt certyfikatu i szyfrów TLS (testssl).
- 5 Dodatki red team / MITM** — `searchsploit · wafw00f · hydra · ettercap`
Uruchamiane tylko na żądanie (patrz profil Red Team).

Raport zbiera wszystko w jeden plik **HTML** (kafelki podsumowania, tabela hostów, znaleziska, sekcja red team) i otwiera go automatycznie w przeglądarce. Surowe dane (`nmap.xml` , `nmap.txt` , logi narzędzi) leżą obok w katalogu skanu.

Profile skanu

⚡ Szybki audyt **--fast**

KIEDY: błyskawiczny przegląd „co tu w ogóle jest”, w kilkadziesiąt sekund.

Co robi Skan 100 najpopularniejszych portów (szybkie tempo `-T4`), lekkie skrypty NSE. Pomija głębokie testy WWW/TLS.

Czas ~20 sekund na host

Narzędzia `netdiscover` `nmap`

🔍 Zwykły audyt **(bez flag)**

KIEDY: standardowy, pełny audyt sieci/serwera.

Co robi Top-1000 portów + skrypty `vuln` (znane podatności) + pełne testy wykrytych serwerów WWW i TLS.

Czas od kilkadziesiątu sekund do kilku minut (zależnie od liczby hostów/usług)

Narzędzia `netdiscover` `nmap` `nikto` `dirb` `testssl`

💪 Głęboki audyt **--aggressive**

KIEDY: chcesz nie przegapić nic — także usług na nietypowych portach.

Co robi To samo co zwykły, ale skanuje **wszystkie 65535 porty** (`-p-`). Dokładniej, ale wolniej.

Czas kilka-kilkanaście minut na host

Narzędzia `netdiscover` `nmap` `nikto` `dirb` `testssl`

Red Team (ofensywa) --redteam

KIEDY: „strzelba nabita” — sprawdzasz, jak daleko dałoby się zajść. Tylko własne systemy!

Co robi	Zwykły audyt + mapowanie exploitów (dopasowuje wersje usług do znanych exploitów), wykrycie WAF i agresywne skrypty NSE (exploit, intrusive, auth). Nie detonuje exploitów — udowadnia i wskazuje , co jest podatne.
Opcje	--brute → hydra (audyt słabych haseł SSH/FTP — może blokować konta!) · --mitm → ettercap (atak MITM/ARP)
Czas	długo (nawet kilkanaście minut — intrusive jest wolne; pasek postępu pokazuje ETA)
Narzędzia	<code>nmap</code> <code>searchsploit</code> <code>wafw00f</code> <code>hydra (opcja)</code> <code>ettercap (opcja)</code>

Blue Team (obrona) blueteam.sh

KIEDY: chcesz nie tylko znaleźć dziury, ale je **ZAŁATAĆ**. Uruchamiasz na serwerze do zabezpieczenia.

Co robi	Audyt konfiguracji i za Twoją zgodą łąta dziury : zaległe aktualizacje bezpieczeństwa, firewall, utwardzenie SSH, ochrona przed brute-force, automatyczne poprawki.
Bezpieczeństwo	Firewall najpierw przepuszcza SSH (zero odcięcia), zmiany SSH walidowane przed restartem, hasła wyłącza tylko gdy masz klucze. Kopia zapasowa + <code>undo.sh</code> = pełne cofnięcie.
Tryby	--dry-run (tylko plan) · interaktywny (zgodą do każdej poprawki) · --auto (wszystko po jednym TAK)
Narzędzia	<code>apt</code> <code>ufw</code> <code>fail2ban</code> <code>unattended-upgrades</code> <code>openssh</code>

Słownik narzędzi

Krótko, co robi każde narzędzie użyte w skanach.

NARZĘDZIE	DO CZEGO SŁUŻY
netdiscover	Rozpoznanie sieci przez zapytania ARP — wykrywa aktywne hosty i ich adresy MAC/producenta.
nmap	Rdzeń skanowania: wykrywa hosty, otwarte porty, wersje usług, system operacyjny; przez skrypty NSE także podatności.
nikto	Skaner serwerów WWW — szuka znanych luk, przestarzałego oprogramowania i niebezpiecznych plików/konfiguracji.
dirb	Wyszukiwanie ukrytych katalogów i plików na serwerze WWW metodą słownikową (np. <code>/admin</code> , <code>/backup</code>).
testssl	Audyt TLS/SSL serwera — wersje protokołu, siła szyfrów, ważność certyfikatu, znane słabości (np. stare TLS).
searchsploit	Lokalna baza exploitów (Exploit-DB) — dopasowuje wykryte wersje usług do znanych, publicznych exploitów i CVE.
wafw00f	Wykrywa, czy serwer WWW stoi za firewallem aplikacyjnym (WAF) i jakiego rodzaju.
hydra	Audyt siły haseł — próbuje zalogować się listą kont/haseł (SSH, FTP...). Wykrywa słabe poświadczenia. Może blokować konta.
ettercap	Narzędzie MITM (man-in-the-middle) / podsłuch ARP. Technika aktywna, domyślnie wyłączona.
ufw	Prosty firewall (zapora) — reguluje, które porty są dostępne z sieci. Blue team włącza go i domyślnie blokuje wejścia.
fail2ban	Blokuje adresy IP po serii nieudanych logowań — ochrona przed atakami brute-force na SSH.
unattended-upgrades	Automatyczne instalowanie poprawek bezpieczeństwa systemu, bez ręcznej ingerencji.

Uwaga sprzętowa: **OpenVAS świadomie pominięty** — na Raspberry Pi 4 z 2 GB RAM jest niepraktyczny (baza podatności chce ~4 GB). Jego rolę przejmują skrypty `vuln` `nmapa` + `nikto` + `testssl` + `searchsploit`, które na tym sprzęcie działają sprawnie.